

CAMS Exam Preparation

Domain D: Tools and Technologies to Fight Financial Crime (20% of Exam)

Advanced AML Training Framework - Extreme Detail Edition

Domain D: 20 percent of CAMS Exam — 10 Lectures — 250+ Detailed Slides — Tools, Technology, Data Quality, AI/ML, Screening

Part D1: Digital Onboarding & Identity (KYC)

Sub-topics (Detailed):

- E-KYC frameworks (FATF Guidance)
- Digital identity tiers (low/medium/high assurance)
- Government vs. private digital ID
- Biometrics: fingerprint, voice, behavioral
- Facial recognition + liveness detection (deepfake defense)
- Document verification (MRZ, holograms, RFID)
- Geolocation + device fingerprinting
- External data sources (credit bureaus, PEP lists, sanctions)
- Fuzzy logic vs. exact matching (phonetic algorithms)
- Batch vs. real-time screening
- Customer segmentation and risk-based onboarding
- Customer experience (CX) friction management

[ALERT] 20% of Domain D exam questions come from onboarding technologies.

FATF Guidance on Digital ID (2019/2020)

Digital identity systems can be used for CDD if they provide **equivalent assurance** to face-to-face verification.

Three Assurance Levels (ISO 29115):

- 1 **Low Assurance:** Self-asserted data, no verification. Not acceptable for AML.
- 2 **Medium Assurance:** Verified against trusted source (e.g., credit bureau). Acceptable for low-risk customers.
- 3 **High Assurance:** In-person or biometric verification with liveness. Required for high-risk/PEP.

FATF Requirements for Digital ID:

- 1 Identity proofing (enrollment) must be robust
- 2 Credential issuance must be secure
- 3 Authentication must be multi-factor where possible
- 4 Ongoing monitoring for credential compromise

[REG] FATF Guidance on Digital ID, paras 78-95. [TRAP] Low assurance digital ID is NOT sufficient for regulated financial services.

Government Digital ID	Private/Digital Identity
Issued by national authorities	Issued by banks, tech companies (e.g., Apple, Google)
Examples: India Aadhaar, Estonia e-Residency, Singapore SingPass	Examples: BankID (Sweden), Verified.Me (Canada)
Typically high assurance	Varies; can be medium-high if properly verified
Can be mandatory for certain transactions	Voluntary, customer chooses
Privacy concerns (government tracking)	Privacy-focused design often better
Acceptance often required by regulation	Acceptance varies by jurisdiction

[ALERT] Government digital ID is NOT automatically compliant; must still meet FATF assurance standards.

Biometric Modalities

Biometrics bind identity to physical characteristics, reducing identity fraud.

Common Biometric Types:

- Fingerprint: High accuracy, but can be lifted from surfaces. Presentation attacks possible.
- Facial recognition: Convenient (selfie), but susceptible to deepfakes, printed photos, masks.
- Voice recognition: Good for phone channels, but replay attacks possible.
- Iris scanning: Very high accuracy, but expensive hardware required.
- Behavioral biometrics: Keystroke dynamics, mouse movements, swipe patterns. Passive, continuous.

Presentation Attacks (Spoofing):

- Printed photo (2D): Defeated by liveness detection (blink, head movement, depth sensing)
- Video replay: Defeated by challenge-response (e.g., "turn head left")
- 3D mask/silicone: Defeated by infrared/thermal detection, texture analysis
- Deepfake: Advanced GAN-generated video; requires multi-modal liveness

[FOCUS] Exam expects you to know that facial recognition alone is insufficient; liveness detection is required.

Active vs. Passive Liveness

Liveness detection ensures the biometric sample comes from a live person at the time of capture.

Active Liveness (User must perform action):

- Instruction: "Blink", "smile", "turn head left", "say a phrase"
- Pro: High security; Con: User friction, accessibility issues
- Common in high-risk onboarding (PEPs, corporate accounts)

Passive Liveness (No user action required):

- Uses micro-movements, skin texture analysis, light reflection, depth mapping
- Analyzes video frames for natural motion (not available in photos/videos)
- Pro: Seamless user experience; Con: Slightly lower security against advanced deepfakes

Technical Defeats:

- Deepfake injection attacks (bypass camera, feed synthetic video directly)
- Replay of previously recorded liveness video (requires randomness in challenge)
- Morphing attacks (combining two faces to fool both recognition and liveness)

[ALERT] Banks must update liveness algorithms regularly as deepfake technology evolves.

Machine-Readable Zone (MRZ) and Security Features

Identity document verification extracts and validates data from passports, driver's licenses, national IDs.

What Document Verification Checks:

- MRZ format compliance (TD1, TD2, TD3, MRV formats)
- Checksum validation (each MRZ line has a check digit)
- Hologram detection (laser engraving, optically variable ink)
- UV feature detection (watermarks, fluorescent fibers)
- Microprinting verification (requires high-resolution scanning)
- RFID chip reading (e-passports - optional, higher assurance)

Common Forgery Techniques:

- Photographic substitution (replacing photo while keeping MRZ)
- Data page replacement (entire page swapped)
- Forged holograms (cheap counterfeits detectable by angle testing)
- Synthetic identity (real document number, fake name - harder to detect)

[FOCUS] Document verification alone is not sufficient; must be combined with biometrics and database checks.

Data Source	Example Providers	Use Case
Credit Reference Agencies	Experian, Equifax, TransUnion, Credit Karma	Address history, credit activity, identity verification (knowledge-based authentication)
Government ID Verification	GB Group, Acuant, Onfido, Jumio	Passport/drivers license validation against issuing authority
Sanctions Lists	OFAC SDN, UNSC, EU Consolidated, UK HMT, DFAT (Australia)	Screening against prohibited persons/entities
PEP Databases	Dow Jones (WorldCheck), Refinitiv (World-Check), LexisNexis, ComplyAdvantage	Identification of politically exposed persons and relatives
Adverse Media	Dow Jones Risk & Compliance, Refinitiv, ComplyAdvantage, Dataminr	Negative news, regulatory actions, court records, investigative journalism
Beneficial Ownership	OpenCorporates, Sayari, Dun & Bradstreet, local registries (UK PSC, US FinCEN BOI)	Corporate UBO identification, ownership structure mapping
Criminal Records	Sterling Check, HireRight	Past convictions relevant to

Exact Matching is Never Sufficient

Sanctions list screening requires algorithmic matching to catch name variations.

Phonetic Algorithms:

- Soundex: First letter + 3 digits based on consonant sounds. *Example: "Smith" and "Smyth" both become S530.*
- Metaphone/Double Metaphone: More sophisticated, handles silent letters, multiple pronunciations. *Example: "Gadaffi" and "Qaddafi" both become KTFF.*
- NYSIIS (New York State Identification and Intelligence System): Optimized for surnames, better than Soundex.

Edit Distance Algorithms:

- Levenshtein distance: Minimum single-character edits (insert, delete, substitute) to change one string to another.
- Damerau-Levenshtein: Also counts transpositions (adjacent character swaps).
- Jaro-Winkler: Gives higher weight to matching prefixes; good for short names.

Token-Based Matching:

- Split name into tokens (first, middle, last, suffix)
- Compare tokens individually with fuzzy logic
- Requires name parsing logic (handles "Jr.", "III", "bin", "bint")

[FOCUS] You do not need to memorize algorithm details, but you MUST know that fuzzy logic/phonetic matching is required.

Batch Screening (Periodic)	Real-Time Screening (Transactional)
Screens entire customer database	Screens each payment before processing
Frequency: daily, weekly, or after sanctions list update	Frequency: per transaction (milliseconds latency)
Detects: customers who became sanctioned after onboarding	Detects: prohibited transactions before funds move
Output: list of potential matches for review	Output: hold/block or allow with alert
Performance: not time-critical (hours allowed)	Performance: sub-second (often <100ms)
False positives: can be manually reviewed over days	False positives: can cause payment delays - requires careful tuning
Required for: all customers, including dormant accounts	Required for: all wire transfers, crypto, instant payments

[ALERT] Failure to screen dormant accounts during batch is a common exam deficiency.

Typical Segments and Controls by Risk Level

Different customer types receive different levels of onboarding scrutiny based on inherent risk.

Customer Type	Minimum Onboarding Controls	Enhanced Controls (if risk indicators)
Retail - Low Risk (pay-roll, low balance)	Basic CIP (name, DOB, address, ID number), identity verification	N/A
Retail - Medium Risk (small business owners)	Basic CIP + beneficial ownership (if entity) + sanctions screening	Source of funds if unusual activity
Retail - High Risk (MSB, NPO, crypto user)	Enhanced CDD + source of funds + PEP screening + adverse media	Senior management approval
Corporate - Simple Structure	CIP for entity + UBOs (25%+ ownership) + sanctions	Business registry verification
Corporate - Complex Structure (trusts, layered)	Full EDD + source of wealth + multi-tier UBO identification + independent verification	On-site visit
PEP (Foreign Senior Official)	Maximum EDD + senior management approval + source of wealth + ongoing monitoring	Enhanced scrutiny for 12-18 months after leaving office
Correspondent Bank	Wolfsberg CBDDQ + on-site inspection + enhanced monitoring	No shell bank clause verification

Balancing Friction and Risk

Too much friction drives customers away; too little creates AML risk.

Low-Friction (Good CX) Techniques:

- Digital onboarding with real-time verification (seconds, not days)
- Risk-based friction: SDD for low-risk, EDD only for high-risk
- Transparent communication: explain why information is needed and legal basis
- Biometric authentication replaces passwords for login
- Mobile-first document upload (scan passport/driver's license with phone camera)
- Pre-filled forms using trusted data sources (credit bureau)

High-Friction (Bad CX) - Regulatory Red Flags (Over-Controlling):

- Requiring in-person branch visit for every account type (even low-risk)
- Asking all customers for source-of-wealth documentation (excessive)
- Repeatedly requesting same documents already provided
- No digital channel for KYC updates (must call or visit branch)
- Excessive hold times for customer verification

Regulatory View: FDIC, OCC, FinCEN have all warned that excessive friction without risk justification is poor management. **[FOCUS] Exam tests ability to apply risk-based friction: low-risk = low friction; high-risk = high friction.**

Part D2: Detection & Monitoring (Ongoing Controls)

Sub-topics (Detailed):

- Transaction monitoring architecture
- Rules-based vs. machine learning (hybrid approach)
- False positives vs. false negatives (calibration)
- Over-filtering threshold trap
- ATL (Above Threshold Limit) testing
- BTL (Below Threshold Limit) testing
- Scenario coverage by typology
- Periodic refresh vs. Perpetual KYC
- Trigger-based review events
- Adverse media continuous screening
- Network analysis (link analysis, centrality)
- Payment screening (SWIFT fields, ISO 20022)
- Blockchain analytics (chain hopping, mixers)
- FATF Travel Rule (VASP obligations)

[INFO] Ongoing controls represent the largest operational investment for most banks.

Typical Data Flow

Core systems → Data aggregation → Scenario execution → Alert generation → Case management → Investigation → SAR filing

Key Components with Technical Details:

- **Data ingestion layer:** Pulls from core banking, payments, CRM, trade finance. Must handle batch (nightly) and real-time (Kafka, RabbitMQ) feeds.
- **Data transformation layer:** Normalizes formats, maps fields, enriches with customer risk rating.
- **Scenario engine:** Executes pre-defined rules (e.g., SQL, Drools) or ML models (Python/TensorFlow). Must scale to millions of transactions.
- **Alert generation:** Creates case in case management system. Includes priority score (high/medium/low).
- **Case management:** Workflow for investigation, evidence collection, narrative writing.
- **Reporting engine:** Files SAR/STR to FIU, management dashboards.

[ALERT] Data latency (delay between transaction and monitoring) is a common deficiency.

Rules-Based Monitoring	Machine Learning Monitoring
Pre-defined, static rules written by analysts	Learns patterns from historical data (supervised, unsupervised, semi-supervised)
Easy to explain and audit (deterministic)	Black box problem - harder to explain (requires XAI)
Low false positives if well-tuned (e.g., 5-10%)	Can have high false positives (20-40%) without careful tuning
Misses new or evolving typologies (rules become stale)	Adapts to new patterns if retrained (online learning possible)
No model drift (rules don't change)	Subject to model drift (performance degrades over time)
Simple implementation (SQL, rules engines)	Complex implementation (requires data science team)
Low computational requirements	High computational requirements (GPUs for deep learning)
Requires manual rule updates (change management)	Can retrain automatically (but validation still required)
Handles structured data only	Handles structured and unstructured (NLP for transaction notes)
Low data volume requirements (works with smaller datasets)	Requires large, labeled datasets for supervised learning

Confusion Matrix for AML Monitoring

	Predicted: Alert	Predicted: No Alert
Actual: Suspicious	True Positive (TP)	False Negative (FN) - MISSED
Actual: Legitimate	False Positive (FP) - WASTE	True Negative (TN)

Why False Negatives are Worse:

- Criminal activity proceeds undetected
- Money laundering continues
- Bank may face enforcement action (civil money penalties)
- Reputational damage if publicly exposed

Why False Positives are Problematic:

- Analyst fatigue (reviewing too many false alerts)
- Operational cost (each false positive costs ~~\$25~~\$75 to review)
- Slows down legitimate transactions (if real-time holds)
- May cause customer attrition (if falsely accused)

[REG] FinCEN expects institutions to prioritize detection effectiveness over operational efficiency. [ALERT] Ever increasing thresholds to reduce false positives = unacceptable false negative risk.

[SCENARIO] Bank of America - 2019 Consent Order (paraphrased) A bank's compliance director, under pressure to reduce alert volume (8,000/month, 96% false positives), raises all monitoring thresholds by 250% across all scenarios. The analytics team warns of increased false negatives, but the director states: "We cannot afford to review 8,000 alerts per month. Any missed activity is acceptable as long as we still file some SARs." Regulators later find that criminal structuring activity below the new thresholds went undetected for 18 months.

What the Exam Tests: Over-filtering creates unacceptable false negative risk.

How to Analyze (Exam Logic):

- ❶ 250% threshold increase is extreme and arbitrary (no data analysis)
- ❷ Many suspicious transactions will fall below new thresholds
- ❸ Director prioritizing cost over effectiveness (violation of risk-based approach)
- ❹ Statement "any missed activity is acceptable" is regulatory non-compliance
- ❺ Regulators will view this as a material deficiency
- ❻ Remediation: back-test missed period, file SARs for identified suspicious activity

[TRAP] Common Distractor: "The director is correctly managing operational efficiency under the risk-based approach." **[CORRECT] Correct Answer: Raising thresholds must be based on data analysis and validation. Effectiveness cannot be sacrificed for efficiency.**

ATL Testing Validates Scenario Effectiveness

Tests that transactions which **should** generate alerts actually do.

Methodology:

- 1 Identify historical confirmed suspicious cases (SARs filed, EDD findings)
- 2 Run those cases through current monitoring scenarios
- 3 Calculate capture rate = (cases that generated alert) / (total cases)
- 4 Expected capture rate: 90-100% for well-tuned scenarios

Low Capture Rate Analysis:

- Below 90%: Investigate root cause
- Scenario logic too narrow (missing variations of typology)
- Thresholds too high (over-filtering)
- Data quality issues (missing transactions, fields)
- Typology has evolved (scenario needs update)

Regulatory Expectation: ATL/BTL testing at least annually, documented, with remediation plans. **[ALERT] A 77% false negative rate on historical SARs is a material deficiency (actual regulatory finding).**

BTL Testing Validates Scenario Specificity

Tests that transactions which **should not** generate alerts do not.

Methodology:

- 1 Identify known legitimate, low-risk transactions (e.g., payroll deposits)
- 2 Run those transactions through current monitoring scenarios
- 3 Calculate false positive rate = (transactions that generated alert) / (total test transactions)
- 4 Expected false positive rate: 0-10% for well-tuned scenarios

High False Positive Rate Analysis:

- Above 10%: Investigate root cause
- Scenario logic too broad (over-inclusive)
- Thresholds too low (under-filtering)
- Customer segmentation issues (same rules for different risk tiers)
- Data quality issues (corrupted fields causing false matches)

Regulatory View: High false positive rates waste resources and cause analyst fatigue, but are less severe than false negatives. **[FOCUS] BTL testing is often overlooked by banks - exam tests whether you know it is required.**

Typology	Example Scenario Logic	Indicators
Structuring (Smurfing)	Aggregate cash deposits $\geq$ \$10,000 within rolling 30-day window	Multiple deposits just below CTR threshold, multiple branches, multiple tellers
Layering	Transfers through 3+ accounts in $\leq$ 24 hours	Rapid movement across accounts, no economic purpose
Trade-Based ML	Invoice value vs. market price variance $\geq$ 20%	Round-dollar trade payments, commodity mismatch, high-risk jurisdiction counterparty
Shell Company Activity	Transfer to/from offshore financial center + no operating expenses	No payroll, no rent, no utilities, but high transaction volume
PEP Activity	Large unexplained transfer ($\geq$ \$100k) + PEP flag	Source of funds not documented, complex ownership structure
NPO/TF Risk	Rapid cash withdrawal from NPO account + conflict zone activity	Donations from unrelated parties, immediate wire to high-risk region
Cybercrime/Ransomware	Payment to known ransomware wallet + unusual timing	Ransomware address on watchlist, payment matches victim report

Beyond Periodic Refresh

Perpetual KYC continuously monitors customer data and risk indicators, triggering reviews when changes occur.

Data Sources for P-KYC:

- Real-time transaction monitoring (behavioral changes)
- Adverse media feeds (continuous news screening)
- Sanctions/PEP list change detection (delta files)
- Corporate registry monitoring (UBO changes, dissolution)
- Negative media monitoring (social media, blogs, forums)

Trigger Events that Require Unscheduled Refresh:

- Change in ownership structure (new UBO $\geq 25\%$)
- Change in business activity (e.g., retail to trade finance)
- Geographic risk change (country added to FATF Grey List)
- Adverse media hit (name appears in corruption investigation)
- PEP designation change (customer becomes PEP)
- Unusual transaction pattern (ATL/BTL violation)
- Law enforcement inquiry (314(a) request, subpoena)
- New sanctions designation (customer appears on SDN list)

[REG] FinCEN CDD Rule (2016) requires banks to understand nature and purpose of relationships and update on a risk basis. [ALERT] Waiting for scheduled 3-year refresh after material change is a control failure.

Continuous Adverse Media Monitoring

Adverse media tools automatically scrape, classify, and match negative news against customer databases.

How Adverse Media Tools Work (Technical):

- 1 **Data ingestion:** Web scraping (news, government sites, court records) + API feeds (Reuters, Bloomberg, regulatory databases)
- 2 **NLP processing:** Named Entity Recognition (NER) extracts persons, organizations, locations. Sentiment analysis classifies negative vs. neutral/positive.
- 3 **Entity resolution:** Matches extracted names to customer database using fuzzy logic (overcomes misspellings, middle names, initials).
- 4 **Risk scoring:** Assigns severity (1-10) based on article source, crime type, conviction status.
- 5 **Alert generation:** Creates case for compliance review if score exceeds threshold.

Credible Sources vs. Non-Credible:

- **[Correct] Credible:** Official gazettes, court records, major news (Reuters, AP, FT), regulatory actions, Interpol notices.
- **[ALERT] Not credible:** Unverified social media, anonymous blogs, competitor accusations, comment sections.

[FOCUS] Exam tests distinction between credible adverse media (actionable) and non-credible (not actionable).

[SCENARIO] CEO named in corruption inquiry - no conviction (actual exam scenario) An EDD analyst discovers through OSINT (open source intelligence) that a corporate customer's CEO was named (not charged, not convicted) in a foreign parliamentary corruption inquiry 18 months ago. Separately, the customer's primary counterparty's director appears on an Interpol Red Notice. The compliance officer argues that since no conviction has occurred, the adverse media is inconclusive and no action is required.

What the Exam Tests: Reasonable suspicion, not conviction, is the standard for AML action.

How to Analyze (Exam Logic):

- 1 OSINT findings from parliamentary inquiry constitute credible adverse media
- 2 Conviction is NOT required for AML action (reasonable suspicion standard)
- 3 Interpol Red Notice alone justifies immediate SAR filing (international wanted person)
- 4 Findings require escalation and potential EDD, relationship reassessment
- 5 "No conviction" is not a defense for ignoring credible adverse media

[TRAP] Common Distractor: "No conviction means the adverse media is inconclusive and can be ignored." **[CORRECT] Correct Answer: OSINT findings do not require a conviction to be actionable. Reasonable suspicion, not proof of guilt, is the standard for AML risk assessment.**

Graph Theory in AML

Network analysis models accounts as **nodes** and transactions as **edges**, then calculates centrality metrics.

Key Centrality Metrics and AML Application:

- **Degree Centrality:** Number of direct connections. High degree = many counterparties Suspicious for money mules many incoming small payments.
- **Betweenness Centrality:** Number of shortest paths passing through a node. High betweenness = critical intermediary in layered network. Suspicious for layering accounts.
- **Eigenvector Centrality:** Connected to other high-centrality nodes. Suspicious for core conspiracy members.
- **PageRank (Google algorithm):** Importance based on inbound connections. Finds central players in ML network.

Clustering Algorithms:

- **Louvain community detection:** Identifies groups of accounts with dense internal connections (e.g., money mule rings).
- **Connected components:** Accounts that transact only within a closed group (no external economic rationale).

[FOCUS] Exam expects you to know that network analysis detects patterns individual monitoring cannot see.

[SCENARIO] Network analysis reveals 23-account money mule ring A bank's network analysis tool identifies a cluster of 23 accounts with: (1) all opened within a 48-hour window; (2) all received small P2P transfers (\$200-\$500) from over 100 different external senders; (3) all then aggregated funds and wired to the same offshore shell company; (4) shared IP addresses (VPN through secrecy haven); (5) shared mobile phone number for verification. Individual transaction monitoring flagged zero accounts as suspicious because each account's activity appeared isolated.

What the Exam Tests: Network analysis detects coordinated patterns that individual account monitoring misses.

How to Analyze (Exam Logic):

- 1 Individual monitoring cannot see cross-account patterns
- 2 Network analysis reveals the coordinated activity across 23 accounts
- 3 The pattern is classic money mule network (layering, consolidation, offshore exit)
- 4 Shared IP addresses and phone numbers are critical indicators (tying accounts together)
- 5 Bank should file SARs on all 23 accounts
- 6 Freeze remaining funds and exit relationships

[TRAP] Common Distractor: "Individual account monitoring is sufficient; network analysis is optional." **[CORRECT] Correct Answer: Network analysis is essential for detecting coordinated criminal networks that individual account monitoring cannot identify. The pattern requires SAR filing.**

SWIFT MT Message Types

Most cross-border wires use SWIFT MT (MT103 customer transfer, MT202 interbank transfer).

Key Fields and Screening Requirements:

Field	Content	Screening Requirement
Field 50 (Ordering Customer)	Name & address of originator	Full screening against sanctions, PEP, adverse media
Field 52 (Ordering Institution)	Originating bank	Sanctions screening of bank
Field 56 (Intermediary Institution)	Correspondent bank	Sanctions screening
Field 57 (Account With Institution)	Beneficiary bank	Sanctions screening
Field 59 (Beneficiary Customer)	Name & address of beneficiary	Full screening against sanctions, PEP, adverse media
Field 70 (Remittance Information)	Free text payment purpose	NLP screening for suspicious keywords (e.g., "discreet", "cash", "shell")
Field 72 (Sender to Receiver Info)	Free text instructions	Screening for evasion patterns

[ALERT] Free text fields (Field 70, 72) are often used to evade screening with misspellings or

How Blockchain Analytics Work

Blockchain surveillance tools map transactions on public ledgers (Bitcoin, Ethereum, etc.) to identify illicit activity.

Technical Capabilities:

- **Address clustering:** Groups addresses owned by the same entity using heuristic analysis (common input ownership, change address patterns, peeling chains).
- **Transaction graph analysis:** Follows funds through multiple hops (5-10+ hops) to trace origin/destination.
- **Risk scoring:** Assigns risk score (0-100) to addresses based on exposure to known illicit sources (darknet markets, mixers, ransomware wallets).
- **Real-time screening:** Alerts when customer sends/receives to/from high-risk address.
- **Travel Rule compliance:** Originator/beneficiary information attached to transactions (required for regulated VASPs).

Major Blockchain Analytics Vendors:

- Chainalysis: KYT (Know Your Transaction) for real-time screening, Reactor for investigation
- Elliptic: Navigator for visual investigation, Lens for real-time risk scoring
- TRM Labs: Transaction monitoring, sanctions screening, case management
- CipherTrace: (now Mastercard) Cross-border crypto intelligence

[ALERT] Privacy coins (Monero, Zcash) cannot be fully traced - many exchanges delist them.

FATF Recommendation 16 (Updated 2019)

Virtual Asset Service Providers (VASPs) must share originator and beneficiary information for transfers above threshold (typically **\$1,000 USD/EUR**).

Required Information for Each Transfer:

- Originator's full name
- Originator's account number (wallet address or account reference)
- Originator's address, national ID number, or date of birth (at least one)
- Beneficiary's full name
- Beneficiary's account number (wallet address)

Originating VASP Obligations:

- Collect and verify required information before transfer
- Transmit information securely to receiving VASP
- Maintain records for at least 5 years
- Immediately freeze and report suspicious transfers

Receiving VASP Obligations:

- Obtain required information from sending VASP
- Take action if information not provided (request, delay, block, enhanced scrutiny)
- Cannot accept transfers without required information (absolute obligation)
- File SAR if information cannot be obtained and transfer is suspicious

[ALERT] Receiving VASP cannot simply ignore missing originator data. "Not my problem" is a violation.

[SCENARIO] VASP receives transfer with no originator information A registered VASP receives a transfer of 4.2 Bitcoin (approximately \$180,000) from another VASP with no originator or beneficiary information attached. The receiving VASP's compliance officer argues that because the customer has already passed KYC, the missing originator data is the sending VASP's problem. The customer states the funds are a personal Bitcoin investment.

What the Exam Tests: Receiving VASP obligations under the Travel Rule.

How to Analyze (Exam Logic):

- ① Receiving VASP has independent obligation to obtain required information (FATF Rec. 16)
- ② Missing information requires follow-up action (request from sending VASP, delay transaction, enhanced scrutiny)
- ③ \$180,000 transfer is well above typical \$1,000 threshold
- ④ Customer's KYC at receiving VASP does NOT substitute for originator data (different person)
- ⑤ If sending VASP cannot provide information, consider blocking and SAR filing

[TRAP] Common Distractor: "The Travel Rule imposes obligations only on the originating VASP." **[CORRECT] Correct Answer: The receiving VASP has an obligation to obtain originator and beneficiary information. If not provided, the receiving VASP must take follow-up action, including enhanced scrutiny and potential SAR filing.**

Part D3: Advanced AI & Machine Learning

Sub-topics (Detailed):

- Supervised vs. unsupervised vs. semi-supervised learning
- Model risk management (MRM) framework
- Independent model validation requirements
- Model drift (concept drift, data drift)
- Explainability (XAI) - SHAP, LIME, counterfactuals
- Black box AI regulatory concerns
- Unsupervised anomaly detection (autoencoders, isolation forests)
- Feature engineering for AML (transaction velocity, counterparty risk)
- Precision, recall, F1 score, AUC-ROC
- AI in investigations (automated narrative generation)

[ALERT] AI models must be explainable and validated - accuracy alone is insufficient.

Supervised Learning (Most Common in AML)

Model learns from labeled historical data (suspicious vs. legitimate transactions).

Examples:

- Random Forest, XGBoost, Gradient Boosting (tree-based models)
- Logistic Regression (simple, explainable)
- Neural Networks (deep learning, powerful but black box)

Pros: High accuracy if labeled data available, can optimize for recall. **Cons:** Requires large labeled dataset (SARs), may not detect new typologies.

Unsupervised Learning (Anomaly Detection)

Model finds patterns without labels - flags outliers.

Examples:

- Autoencoders (neural networks that reconstruct input, high reconstruction error = anomaly)
- Isolation Forests (random forest that isolates anomalies)
- One-Class SVM (learns boundary around normal data)
- K-means clustering (distant points = anomalies)

Pros: Can detect novel typologies, no labeled data needed. **Cons:** Very high false positives (often 90%+), hard to validate.

[FOCUS] Hybrid: supervised for known typologies, unsupervised for novel anomalies.

Regulatory Requirements for Model Validation

All AML models (transaction monitoring, sanctions screening, fraud detection) are subject to model risk management.

Key MRM Components (SR 11-7):

- 1 **Model Inventory:** All models documented, owners assigned, risk tier (high/medium/low)
- 2 **Model Development Documentation:** Theoretical basis, assumptions, limitations, data sources
- 3 **Independent Validation:** Before deployment and periodically after (annually for high-risk)
- 4 **Performance Monitoring:** Ongoing tracking of precision, recall, false positive rate, drift
- 5 **Model Governance:** Policies, procedures, approval authorities, escalation path

Validator Independence Requirements:

- Validator cannot be involved in model development
- Validator must report functionally to independent risk management (not to model development)
- External validation for high-risk models (e.g., sanctions screening)

Validation Report Must Address:

- Conceptual soundness (does model logic make sense?)
- Data quality (is input data complete and accurate?)
- Outcomes analysis (precision, recall, ATL/BTL)
- Benchmarking (comparison to alternative models)
- Limitations and compensating controls

[ALERT] A model that cannot be validated (black box AI) is a regulatory violation.

Why ML Models Degrade Over Time

Models are trained on historical data. When the real world changes, model performance degrades.

Concept Drift (Most Dangerous):

- The relationship between input features and target variable changes.
- Example: Criminal typology shifts from cash structuring to cryptocurrency layering. Old model learned patterns of cash behavior, no longer relevant.
- Detection: Monitor recall rate (capture of new SARs). Decline indicates concept drift.
- Remediation: Retrain model with new data including new typology.

Data Drift (Feature Distribution Changes):

- Input data distribution changes, but relationship remains same.
- Example: Customer transaction volume increases 180% after product launch. Model trained on lower volumes now sees many false positives.
- Detection: Monitor feature distributions (KS test, population stability index).
- Remediation: Recalibrate thresholds or retrain with new data.

Regulatory Expectation: Annual model validation (minimum), trigger-based validation after material changes. **[FOCUS] Exam scenario: model not recalibrated for 3.5 years despite new products and typologies - material deficiency.**

Why Explainability Matters

Regulators require that analysts understand why a transaction was flagged. SAR narratives must include rationale.

SHAP (SHapley Additive exPlanations):

- Game-theoretic approach: assigns each feature a "importance value" for the prediction.
- Output: "Transaction amount \$25,000 contributed +0.8 to risk score; counterparty high-risk jurisdiction contributed +0.5; total 1.3 exceeds threshold 1.0."
- Analysts can see which features drove the alert.

LIME (Local Interpretable Model-agnostic Explanations):

- Creates a simple, interpretable model (e.g., linear regression) locally around the prediction.
- Explains individual predictions, not global model behavior.
- Works with any black box model.

Counterfactual Explanations:

- "If the transaction amount had been \$19,000 instead of \$25,000, it would not have been flagged."
- Useful for customer disputes.

[ALERT] Black box AI with no explainability will be rejected by regulators regardless of accuracy.

How Autoencoders Detect Anomalies

Neural network trained to reconstruct normal transactions. High reconstruction error = anomaly (potential suspicious).

Technical Architecture:

- Encoder: Compresses input (e.g., 100 transaction features) into lower-dimensional representation (e.g., 10 latent variables).
- Decoder: Reconstructs original input from latent representation.
- Training: Minimize reconstruction error on normal transactions only.

Inference (Monitoring):

- Feed transaction through autoencoder.
- Calculate Mean Squared Error (MSE) between input and reconstruction.
- If MSE $\geq$ threshold, flag as anomaly.

Pros and Cons:

- **[Correct] Pro:** No labeled data required, can detect novel typologies.
- **[ALERT] Con:** Very high false positives (90%+), hard to explain why transaction was flagged, requires threshold tuning.

[FOCUS] Exam tests that unsupervised models still require independent validation, despite being "supplemental".

Key Performance Metrics for AML Models

Regulators expect banks to track and report these metrics.

Metric	Formula	AML Interpretation
Precision	$TP / (TP + FP)$	Of all alerts, how many were true positives? (low precision = many false positives)
Recall (Sensitivity)	$TP / (TP + FN)$	Of all suspicious activity, how many generated alerts? (low recall = missed suspicious activity)
F1 Score	$2 * (Precision * Recall) / (Precision + Recall)$	Harmonic mean - balances precision and recall
Specificity	$TN / (TN + FP)$	Of all legitimate activity, how many did NOT generate alerts? (low specificity = many false positives)
AUC-ROC	Area Under Receiver Operating Characteristic Curve	Model's ability to distinguish suspicious from legitimate (0.5 = random, 1.0 = perfect)

Target Ranges for AML (Typical):

- Recall: ≥80% (regulators prioritize detection)

Part D4: Strategy, Data & Governance

Sub-topics (Detailed):

- Data quality dimensions (completeness, accuracy, timeliness, consistency)
- Silent data feed failures (reconciliation controls)
- Unlinked transactions (NULL Customer ID)
- Data quality KPIs and governance
- Investigation tools (case management, link analysis, timeline)
- OSINT credible sources vs. non-credible
- Privacy-enhancing technologies (PETs)
- GDPR / AML retention exception
- Tool selection criteria (risk alignment, integration, TCO)
- Integration architecture (APIs, data latency, feed failures)
- Operational effectiveness vs. efficiency
- Risk-based resource prioritization

[INFO] Data quality is the foundation - all other controls depend on it.

Six Key Dimensions (DAMA DMBOK)

Data quality is multi-dimensional; failure in any dimension affects AML effectiveness.

Dimension	Definition	AML Example
Completeness	All required fields are populated (no nulls)	Customer ID = NULL on 12% of transactions = monitoring failure
Accuracy	Data correctly reflects real-world values	Amount field has decimal error: \$1,000 vs. \$10,000 = missed SAR
Timeliness	Data available when needed (latency)	24-hour delay in feed = criminals have window to move funds
Consistency	Same data has same format across systems	"John Smith" in core, "J. Smith" in monitoring = screening miss
Validity	Data conforms to defined business rules	Date field "2025-13-01" (invalid month) = monitoring error
Uniqueness	No duplicate records for same entity	Same customer two IDs = split KYC, missed aggregation

[SCENARIO] 34% of international wires missing for 14 months - actual exam scenario A bank's transaction monitoring system relies on daily data feeds from 17 upstream systems. An audit reveals that for 14 months, the feed from the international wire system silently failed for 34% of all wires. Those transactions never entered the monitoring system, never generated alerts, and were never reviewed. Estimated \$340 million in wires were not monitored. The failure was a technical misconfiguration with no error messages. No reconciliation controls existed to detect the gap.

Technical Root Causes:

- 1 Change in source system field mapping (e.g., "customer.id" renamed to "cust.id")
- 2 API pagination limit exceeded (only first 1,000 of 10,000 transactions ingested)
- 3 Network firewall rule blocking specific ports (no error logged)
- 4 File encoding mismatch (UTF-8 vs. ASCII causing silent truncation)

How to Analyze (Exam Logic):

- 1 34% missing = massive monitoring gap (material deficiency)
- 2 No alerts could be generated for missing transactions
- 3 Absence of reconciliation controls is foundational failure
- 4 Remediation: fix root cause AND review missed transactions retrospectively
- 5 SARs must be filed for any suspicious activity identified
- 6 This is a violation regardless of accidental cause

[TRAP] Common Distractor: "The misconfiguration was accidental, so no compliance violation occurred." **[CORRECT] Correct Answer: The bank must have controls to verify complete data ingestion. The 14-month gap requires retrospective review and SAR filing. Data quality is a compliance responsibility.**

Reconciliation Requirements to Detect Silent Failures

Banks must prove that ALL transactions entered the monitoring system.

Required Controls by Control Type:

- **Record Count Reconciliation:** Source system transaction count vs. monitoring system intake count (daily). Discrepancy $\geq 0\%$ = investigate.
- **Total Dollar Volume Reconciliation:** Source system total volume vs. monitoring system total volume (daily). Discrepancy $\geq 1\%$ = investigate.
- **Hash Total Reconciliation:** Run hash algorithm (e.g., SHA-256) on key fields (customer ID, amount, date, transaction ID). Compare hash between source and target. Any mismatch = data corruption.
- **Exception Report:** Automated report for ANY discrepancy. Must include root cause and resolution.
- **Timely Resolution:** 24-48 hours maximum for investigation and fix.
- **Escalation Path:** Unresolved exceptions escalate to CCO within 5 days, Board within 30 days.
- **Audit Trail:** Log all reconciliation runs, exceptions, resolutions.

Common Reconciliation Failures (Exam Scenarios):

- No reconciliation at all (most severe)
- Weekly reconciliation when daily required
- No dollar volume reconciliation (only record count)
- No hash reconciliation (can't detect data corruption)
- Exceptions ignored without resolution

[ALERT] Audit finding: "The bank could not demonstrate completeness of transaction monitoring data."

[SCENARIO] 12% of transactions have NULL Customer ID A bank's transaction monitoring system flags a series of large wire transfers. When the analyst tries to investigate, the system shows the transactions are associated with "Customer ID: NULL". The data issue has been present for 8 months. IT explains that when customers open accounts through the mobile app, the unique identifier sometimes fails to populate in the monitoring system. Approximately 12% of transactions cannot be linked to any customer record. The compliance team cannot determine which customer conducted which transaction.

What the Exam Tests: Importance of customer identification in monitoring.

How to Analyze (Exam Logic):

- 1 Unlinked transactions cannot be investigated properly
- 2 Bank cannot determine customer risk or conduct CDD
- 3 Cannot file accurate SARs without customer identification
- 4 Root cause must be fixed immediately
- 5 Process needed to identify and investigate orphaned transactions retrospectively
- 6 Consider SAR filing for suspicious unlinked transactions (based on transaction pattern alone)

[TRAP] Common Distractor: "IT issues are operational and not a compliance concern."

[CORRECT] Correct Answer: Missing customer identification data is a material AML deficiency. Fix the root cause and develop a process to identify and investigate orphaned transactions.

Shared Responsibility Model

Data quality is not just IT's problem - compliance must define requirements and monitor quality.

Role Accountabilities:

- **Compliance:** Define data requirements for monitoring (what fields, what formats, what latency). Establish data quality KPIs. Monitor and report data quality metrics. Escalate material gaps.
- **IT:** Implement controls to meet requirements. Build reconciliation. Fix root causes of data failures. Provide SLAs for data availability.
- **Business:** Ensure source system data quality at point of entry. Validate customer data during onboarding. Correct data errors.
- **Internal Audit:** Periodically test data quality controls. Report deficiencies.

Required Data Quality KPIs (Reported Monthly to Management/Board):

- Data completeness % by source system (target: 99.9%+)
- Data timeliness (average latency from transaction to monitoring)
- Data accuracy % (error rate in critical fields)
- Reconciliation exception rate and aging
- Number of unlinked transactions (NULL customer ID)
- Number of failed data feeds and recovery time (MTTR)
- Duplicate record rate across systems

[ALERT] Compliance cannot accept whatever data IT provides. Compliance must define requirements and monitor quality.

Core Functionality for AML Investigators

Case management systems (CMS) support the investigation workflow from alert to SAR.

Must-Have CMS Capabilities:

- **Alert intake:** Auto-creation of cases from monitoring system alerts, with priority scoring (high/medium/low)
- **Data aggregation:** Automatically pull KYC, transactions, sanctions hits, adverse media, network links into single case file
- **Link analysis visualization:** Graph display of entity relationships, transaction flows
- **Timeline analysis:** Chronological view of customer activity (list view + graph)
- **Document management:** Store investigation notes, evidence, screenshots, emails
- **SAR generation:** Auto-populate SAR/STR forms from case data (populated by investigator, not auto-filed)
- **Audit trail:** Log all actions (who viewed what, when, what decisions made)
- **Collaboration tools:** Notes, tasks, assignments, supervisor approval workflow
- **Reporting dashboards:** Management view of queue size, aging, SAR volume

[ALERT] Audit trail is mandatory - regulators will request logs of who accessed which cases.

Credible OSINT Sources (Actionable)

Only information from authoritative, verifiable sources should be used in AML investigations.

Credible Sources by Category:

- **Government official sources:** Sanctions lists (OFAC, UN, EU, UK HMT), corporate registries (Companies House, SEC EDGAR), court records (PACER), government gazettes.
- **Law enforcement:** Interpol Red Notices (www.interpol.int), FBI Most Wanted, Europol wanted lists.
- **Regulatory:** FinCEN enforcement actions, SEC enforcement, FCA fines, OCC consent orders.
- **Investigative journalism:** ICIJ (Offshore Leaks, Panama Papers), OCCRP, Bellingcat, Reuters Investigates.
- **Major news:** Reuters, Bloomberg, Financial Times, Associated Press, Wall Street Journal, BBC.
- **Commercial databases:** Dun & Bradstreet, LexisNexis, Dow Jones Factiva, Sayari.

Non-Credible Sources (Not Actionable Alone):

- Unverified social media (Twitter, Facebook, LinkedIn without verification)
- Anonymous blogs (Medium, WordPress with no author)
- Unmoderated forums (Reddit, 4chan)
- Competitor allegations without evidence
- Personal websites with no attribution

[FOCUS] Exam tests distinction - know which sources are credible for AML decisions.

Balancing AML Obligations and Privacy Rights

Technology can help comply with both AML and privacy laws (GDPR, CCPA, etc.).

PETs Applicable to AML:

- **Data Minimization:** Collect only data required for AML (not extraneous personal data). GDPR Article 5(1)(c).
- **Anonymization:** Remove all personal identifiers where not needed (e.g., aggregated reports). Cannot be reversed.
- **Pseudonymization:** Replace identifiers with tokens (e.g., customer ID replaced with token). Reversible with key. GDPR encourages pseudonymization.
- **Encryption:** Protect data at rest (AES-256) and in transit (TLS 1.3). Required for data protection laws.
- **Access Controls:** Role-based access (RBAC) - investigators see only data needed for their cases. Log all access.
- **Audit Logs:** Track all access to sensitive AML data. Required for breach notification.
- **Secure Data Sharing:** Encrypted channels for 314(b) sharing, FIU reporting (GoAML, secure FTP).

[ALERT] AML obligations override privacy rights for required data retention (e.g., 5-year recordkeeping).

[SCENARIO] Bank receives right to erasure request for SAR customer A European bank receives a GDPR "right to erasure" request from a customer demanding deletion of all personal data, including KYC documents and transaction records. The customer was the subject of a SAR filed 18 months ago. The Data Privacy Officer argues GDPR requires deletion. The AML Officer argues AML recordkeeping requires retention (minimum 5 years).

What the Exam Tests: GDPR exception for legal obligations (AML retention).

How to Analyze (Exam Logic):

- 1 GDPR Article 17(3)(b) exempts data retention required by Union or Member State law
- 2 AML directives (4AMLD, 5AMLD) require 5-year retention of records
- 3 Bank can lawfully refuse to delete AML-required records
- 4 SAR confidentiality (non-tipping off) also prohibits acknowledging SAR existence to customer

[TRAP] Common Distractor: "GDPR's right to erasure is absolute and overrides all other laws." **[CORRECT] Correct Answer: AML retention requirements are a legal exception to GDPR erasure rights. The bank may refuse deletion for records it is required to retain.**

Evaluating AML Technology Vendors

Selecting the right tool requires balancing multiple factors; cheapest is rarely best.

Key Selection Criteria with Sub-Questions:

- **Risk Alignment:** Does the tool address your specific ML/TF risks (trade finance, crypto, correspondent banking, etc.)? Request vendor typology coverage list.
- **Regulatory Acceptance:** Has the vendor been examined by regulators (OCC, FinCEN, FCA)? Do peer institutions use it? Any public enforcement actions against vendor?
- **Integration Complexity:** APIs available (REST, GraphQL)? Data format compatibility with core banking system? Proof of concept with your data required.
- **Performance Metrics:** Request vendor's false positive rate, recall rate, precision on independent test data (not vendor's own marketing numbers).
- **Explainability:** Can the tool explain WHY it flagged a transaction? Required for AI models (SHAP, LIME, rule extraction).
- **Total Cost of Ownership (TCO):** License fees + implementation + integration + training + ongoing maintenance + hardware/cloud costs.
- **Vendor Stability:** Financial health, support responsiveness, update frequency, data privacy compliance (GDPR, CCPA).
- **Scalability:** Can it handle 2x or 5x current transaction volume without performance degradation? Stress test results?

[ALERT] Failure to conduct proper due diligence on a vendor is a regulatory deficiency.

Integration Risk Points (Exam Scenarios)

A tool is only as good as its data feeds. Poor integration = poor detection.

Systems That Must Integrate:

- Core Banking System: Customer master, account balances, transaction history
- Payment Systems: SWIFT, ACH, Fedwire, SEPA, crypto wallets (via API)
- CRM: Customer contact info, relationship manager assignments
- Case Management: Workflow integration (alert → case → SAR)
- Data Lake/Warehouse: Historical data for model training and validation
- Sanctions Lists: Real-time API feeds for list updates (avoid manual downloads)

Integration Risk Points (Common Exam Scenarios):

- **Data format mismatches:** CSV vs. JSON vs. XML vs. proprietary formats
- **Data latency:** Transaction at 9:00 AM, monitoring system sees it at 9:00 PM (criminal window)
- **Silent feed failures:** No error message, data just missing (most dangerous)
- **API rate limiting:** Vendor caps queries at 1,000/sec, but bank has 5,000/sec = queued/dropped transactions
- **Version compatibility:** Core system upgrade breaks integration for weeks

Best Practices:

- Always require a proof of concept (POC) with your actual data
- Test data feeds thoroughly before go-live (including failure scenarios)
- Establish reconciliation between source and target
- Document integration architecture and data flows

[ALERT] API rate limiting is a common hidden risk - test at peak volume.

Balancing Two Competing Priorities

Regulators prioritize effectiveness (catching bad activity) over efficiency (cost per alert).

Measuring Operational Effectiveness (Regulator Focus):

- False negative rate (missed suspicious activity) - should be $\leq 5\%$
- SAR quality (actionable intelligence for law enforcement) - percentage of SARs that result in investigation or prosecution
- Investigation timeliness (alerts reviewed within target timeframes) - e.g., 48 hours for high-priority alerts
- Alert-to-SAR conversion rate (meaningful alerts vs. noise) - 2-5% is typical
- Audit findings - fewer findings indicate better controls
- Back-testing results - historical SAR capture rate

Measuring Operational Efficiency (Bank Management Focus):

- Cost per alert reviewed (typical \$25-\$75)
- Time per investigation (hours per case)
- False positive rate (higher = less efficient)
- Analyst utilization rate most of time on productive investigation
- SAR filing rate relative to peer institutions (too low or too high both scrutinized)

[ALERT] Efficiency improvements that increase false negatives (e.g., raising thresholds) are unacceptable.

Aligning Investment with Risk Assessment

The risk-based approach means investing most heavily where risk is highest.

High-Risk Areas Requiring More Investment:

- **Correspondent banking** (highest risk): Enhanced due diligence (Wolfsberg CBDDQ), on-site inspections, dedicated monitoring team, automated screening of nested accounts.
- **Private banking / wealth management** (PEP risk): Enhanced CDD, source of wealth verification, senior management approval, relationship manager oversight.
- **Trade finance** (TBML vulnerability): Automated invoice matching, country risk scoring, counterparty screening, dedicated TBML analysts.
- **Virtual assets** (emerging typologies): Blockchain analytics (Chainalysis/Elliptic), Travel Rule compliance, mixer/darknet monitoring.
- **Cross-border payments** (jurisdictional risk): Enhanced payment screening, jurisdiction risk scoring, correspondent bank restrictions.
- **Cash-intensive businesses** (structuring risk): Aggregated cash reporting, geographic profiling, branch-level monitoring.

Lower-Risk Areas for Lighter Investment (Simplified Due Diligence):

- Domestic retail payroll accounts (low transaction velocity, predictable patterns)
- Low-balance consumer accounts (<\$5,000 balance)
- Government benefit disbursement accounts (limited usage)
- Regulated public companies (subject to disclosure)

[ALERT] Applying the same resources to all customers violates the risk-based approach.

Domain D Summary: Top 50 Most Tested Concepts

- 1 Silent data failure = monitoring gap
- 2 Reconciliation controls prevent undetected data loss
- 3 Fuzzy logic required for sanctions screening
- 4 False negatives worse than false positives
- 5 Model drift requires regular recalibration
- 6 Explainability required for AI models (XAI)
- 7 E-KYC requires liveness detection
- 8 Network analysis detects money mule rings
- 9 Travel Rule applies to both sending and receiving VASPs
- 10 Adverse media does NOT require conviction
- 11 Data quality is compliance responsibility
- 12 Perpetual KYC $\neq$ periodic refresh
- 13 Trigger-based refresh required for material changes
- 14 ATL/BTL testing validates scenario effectiveness
- 15 Rules-based + ML hybrid is best practice
- 16 Unsupervised models still require validation
- 17 SWIFT fields requiring screening: 50, 52, 56, 57, 59, 70
- 18 Blockchain analytics required for VASPs
- 19 Privacy coins and mixers require EDD
- 20 Receiving VASP cannot ignore missing Travel Rule data
- 21 GDPR has AML retention exception (Article 17(3))
- 22 OSINT must use credible sources only
- 23 Tool selection must consider integration and scalability
- 24 Effectiveness prioritized over efficiency
- 25 Risk-based approach drives resource allocation
- 26 Model risk management requires independent validation
- 27 Sanctions screening requires fuzzy logic, not exact matching
- 28 Over-filtering increases false negatives
- 29 Scenario coverage must address all typologies
- 30 Investigation tools require audit trails
- 31 Biometrics alone insufficient without liveness
- 32 MRZ validation for identity documents
- 33 Hash totals for data reconciliation
- 34 Concept drift vs. data drift
- 35 SHAP/LIME for model explainability
- 36 Precision, recall, F1, AUC-ROC
- 37 Autoencoders for anomaly detection
- 38 High betweenness centrality = layering account
- 39 FATF digital ID assurance levels (low/medium/high)
- 40 Silent feed failures are most dangerous
- 41 NULL Customer ID = unlinked transactions
- 42 API rate limiting causes missed transactions
- 43 Proof of concept required before vendor contract
- 44 Analyst fatigue from high false positives
- 45 Board reporting on data quality metrics
- 46 Non-tipping off for SAR customers
- 47 Interpol Red Notice = immediate SAR
- 48 Correspondent banking highest risk
- 49 Nested account activity requires EDD
- 50 Shell bank prohibition (USA PATRIOT Act)

- 34% missing data for 14 months → Data failure
- NULL Customer ID on transactions → Unlinked transactions
- No reconciliation controls → Undetected gaps
- 77% false negative rate → Material deficiency
- No recalibration for 3.5 years → Model drift
- Black box AI with no explainability → Governance failure
- Exact-string matching only → Sanctions screening failure
- No liveness detection → Spoofing vulnerability
- No adverse media review → Missed risk indicators
- No network analysis → Missed mule rings
- Missing Travel Rule data accepted → VASP violation
- No ATL/BTL testing → Unvalidated scenarios
- Only annual refresh after material changes → Control gap
- Same onboarding for all customers → RBA violation
- No independent model validation → MRM failure
- API rate limiting untested → Transaction loss
- No hash reconciliation → Data corruption undetected
- 24+ hour data latency → Criminal window

- Domain D is 20% of CAMS exam - do not underestimate
- Data quality is a **COMPLIANCE** responsibility, not just IT
- Silent data failures (no error messages) are the most dangerous
- **FALSE NEGATIVES** are worse than false positives (regulator priority)
- Fuzzy logic is **REQUIRED** for sanctions screening (exact matching insufficient)
- ML models require explainability (SHAP/LIME) and ongoing validation
- Model drift requires regular recalibration (annual minimum)
- Travel Rule applies to **BOTH** sending and receiving VASPs
- E-KYC without liveness detection can be spoofed (deepfakes)
- Adverse media findings do **NOT** require conviction (reasonable suspicion)
- Network analysis detects patterns individual monitoring misses
- GDPR has an AML retention exception (Article 17(3)(b))
- Credible OSINT sources: government, courts, reputable journalism
- Privacy coins and mixers require EDD (high risk)
- Effectiveness & efficiency (regulator priority)
- Risk-based approach drives resource allocation
- Always require a proof of concept (POC) before signing vendor contract
- Test reconciliation controls and API rate limits at peak volume

[Correct] Good luck on the exam!